TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

CISA adds exploited Adobe Commerce "PolyShell" and Google Brotli flaws to KEV

From **Cybersecurity Brie ng** · 2026-10-27 to 2026-10-28 (US, Global, Industry; last 24 hours) and 2026-10-23 to 2026-10-28 (Indianapolis, State of Indiana) · Brie ng generated 2026-10-28

REPORT ID	VERSION	HANDLING
LIT-CTI-20261028-03	1.0 · 2026-10-28 08:08 EDT	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
United States	2026-10-27	No update
CVES	**ANALYST**	
CVE-2026-48356 (CVSS 9.3), CVE-2026-111497 (CVSS 9.2)	Nick Sturgeon	

VULNERABILITY | CRITICAL | ACTIVELY EXPLOITED | OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

On 2026-10-27 CISA added two critical flaws to the Known Exploited Vulnerabilities (KEV) catalog. Federal civilian agencies must fix both by 2026-11-10 [S4] [S1]. The first is CVE-2026-48356 ("PolyShell"), an unrestricted file upload flaw in Adobe Commerce and Magento Open Source. Adobe fixed it in APSB26-73 on 2026-07-14 [S2] [S5]. Sansec found that the flaw sits in the unauthenticated REST API endpoints for guest cart items. Attackers can upload image/PHP polyglot files to pub/media/custom_options/quote/, and on some web server setups those files run as code [S8]. Mass exploitation began in March 2026. By mid-April, Sansec had seen malicious uploads on 82% of the stores it tracked [S8] [S9]. On 2026-10-24 Sansec published research on a long-running campaign that injects a JavaScript loader into Magento's cms_block table. It has hit 953 stores since July 2025 across five loader domains. The newest domain, deepveindrilling[.]com, first appeared on 2026-10-07 [S7]. Sansec has not recovered the current final payload. Payloads seen in December 2025 led to crypto-themed domains, including a Ledger look-alike [S7].

The second is CVE-2026-111497 ("Node2Shell", also called Broccoli2Shell and HTTP2Shell). It is an out-of-bounds write caused by an unchecked return value in Google's Brotli decoder, versions 1.0.3 through 1.2.0. It is fixed in Brotli 1.0.10, 1.1.1 and 1.2.1, released 2026-10-21 [S3] [S6]. Node.js ships its own copy of Brotli and fixed it in 22.23.4, 24.22.1 and 26.12.1. Node.js offers no workaround, and end-of-life lines will not be patched [S11] [S10]. Any application that decompresses attacker-supplied Brotli data can be exposed. This includes inbound request bodies with Content-Encoding: br (for example, Express 5 default body parsing) and outbound fetch() calls that decode Brotli responses [S10]. Other affected

software includes Bun, Python Brotli/brotlicffi, Envoy/Istio, PHP, .NET, the Ruby brotli gem and Linux distribution packages [S1] [S10]. ELLIO saw a scanner using the user agent node2shell-check map which hosts decompress Brotli. On 2026-10-26 it reported an exploit attempt from 94.154.43[.]7 aimed at the official Node.js v24.22.0 x86-64 build [S10]. In ELLIO's own testing, that payload never reached its final stage. Failed attempts still crash worker processes and can leave core dumps that contain secrets [S10]. Through The Hacker News, Previdian reported one honeypot exploitation attempt from a US IP, and Wiz estimated that 91% of cloud environments have vulnerable resources [S1]. We could not check either figure against the original source.

EPSS scores on 2026-10-27 were 0.306 (98.2nd percentile) for CVE-2026-48356 and 0.555 (99.0th percentile) for CVE-2026-111497 [S12]. Several points are still unknown. CISA lists ransomware use as Unknown for both [S4]. Adobe's bulletin, last updated in August, still says it knows of no exploits in the wild and lists a CVSS of 9.6, while the CVE record gives 9.3 [S2] [S5]. Sources do not agree on when the Magento campaign began. Sansec's loader activity dates to July 2025, before PolyShell was discovered, so earlier infections probably came through other entry points such as SessionReaper (CVE-2025-54236) [S7].

What to do: apply the APSB26-73 July 2026 patch releases to every Magento/Adobe Commerce store. Block execution and web access under pub/media/custom_options/. Then hunt for compromise even on patched stores, because the attacker keeps database write access. That means searching cms_block and cms_page, looking for accesson.php and uploaded files, checking admin_user for unknown accounts, and rotating database, admin and API credentials [S7] [S8]. For Brotli, upgrade Node.js and every runtime, container image and appliance that embeds Brotli. Rebuild images and restart processes. Do not rely on process.versions.brotli, which reports 1.2.0 on both patched and unpatched builds. Where you can, reject inbound Content-Encoding: br until patching is done [S10].

Key judgments

VERY LIKELY · HIGH CONFIDENCE
Magento stores already compromised through PolyShell or earlier entry points will stay infected after patching unless they also clean the database and rotate credentials. Sansec has seen the operator rewrite CMS blocks on stores that were already patched. [S7] [S8] [S9]

LIKELY · MODERATE CONFIDENCE
In the next 30 days the Magento CMS-block loader operator will move to at least one new loader domain or change its loader technique, as it did four times between July 2025 and October 2026. [S7]

ALMOST CERTAIN · MODERATE CONFIDENCE
Internet-wide scanning and crash-inducing exploit attempts against Brotli-decoding services (Node.js and others) will continue and grow through November 2026. [S10] [S1] [S11]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE
Within 30 days, a version of the exploit that reliably achieves remote code execution against multiple stock Node.js builds will be seen in the wild. [S10] [S11]

> **VERY LIKELY · MODERATE CONFIDENCE**
> Copies of Brotli embedded in vendor appliances, proxies, containers and compiled binaries will remain unpatched in many environments well past the 2026-11-10 KEV due date. [S1] [S4] [S10]

INDICATORS OF COMPROMISE

The Magento indicators come from Sansec research published between March and 2026-10-24. The CMS-loader domains are current through October 2026. The PolyShell scanning IPs date from March 2026 and include shared cloud and CDN addresses, so treat them as stale and low-fidelity. The Node2Shell indicators come from ELLIO's 2026-10-25/26 reporting. Neither Adobe nor CISA published indicators.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`deepveindrilling[.]com`	Current CMS-block loader and fingerprinting domain. Registered 2026-10-06 and first loaded by stores 2026-10-07.	REPORTED	2026-10-07	[S7]
url	`hxxps[://]deepveindrilling[.]com/?s=d35c5031`	Version 1 loader script URL injected into cms_block (October 7-8, 2026).	REPORTED	2026-10-07	[S7]
url	`hxxps[://]deepveindrilling[.]com/?s=49b7ca5f&fp=`	Version 2 fingerprinting loader endpoint. Receives browser fingerprint data from 2026-10-23 onward.	REPORTED	2026-10-23	[S7]
domain	`additionalver[.]com`	Earlier CMS-block loader domain (Keitaro TDS). 246 stores. About 52,000 visitor browser reports.	REPORTED	2026-06-08	[S7]
url	`hxxps[://]additionalver[.]com/Mb2z8J`	Keitaro campaign URL used by the loader.	REPORTED	2026-06-08	[S7]
domain	`lanhd6549tdhse[.]top`	Loader domain from the PolyShell mass wave of 2026-03-30 (471 stores in one hour). 355 stores in total.	REPORTED	2026-03-30	[S7] [S9] [S8]
url	`hxxps[://]lanhd6549tdhse[.]top/KZtBscgb`	Keitaro loader URL from the March 2026 PolyShell wave.	REPORTED	2026-03-30	[S7] [S9]
domain	`neswnsssn[.]click`	CMS-block loader domain. 494 stores.	REPORTED	2025-12-12	[S7]
url	`hxxps[://]neswnsssn[.]click/PKgJDPfF`	Keitaro loader URL.	REPORTED	2025-12-12	[S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
domain	`manulfie[.]click`	Earliest CMS-block loader domain for this operator. 863 stores.	REPORTED	2025-07-09	[S7]
url	`hxxps[://]manulfie[.]click/GKTD8cBz`	Keitaro loader URL.	REPORTED	2025-07-09	[S7]
domain	`hdfdsi84j3h[.]top`	Related Keitaro loader domain listed by Sansec.	REPORTED		[S7]
url	`hxxps[://]hdfdsi84j3h[.]top/sFnnPFHm`	Keitaro loader URL.	REPORTED		[S7]
domain	`c85grt98sd[.]com`	Related Keitaro loader domain listed by Sansec.	REPORTED		[S7]
url	`hxxps[://]c85grt98sd[.]com/1kYrdH`	Keitaro loader URL.	REPORTED		[S7]
domain	`leqdger[.]click`	Payload domain imitating the Ledger crypto wallet brand. Seen in December 2025.	REPORTED	2025-12	[S7]
url	`hxxps[://]leqdger[.]click/ssl/`	Payload script path served to selected visitors.	REPORTED	2025-12	[S7]
domain	`crypto-insider[.]top`	Payload domain seen in December 2025.	REPORTED	2025-12	[S7]
url	`hxxps[://]crypto-insider[.]top/ssl/`	Payload script path served to selected visitors.	REPORTED	2025-12	[S7]
domain	`jslibrary[.]net`	Domain Sansec says to search for in CMS content on PolyShell-compromised stores.	REPORTED		[S8]
domain	`canevaslab[.]com`	Domain Sansec says to search for in CMS content on PolyShell-compromised stores.	REPORTED		[S8]
other	`localStorage key: fpCode`	Version 1 loader replays the stored payload by placing it in a hidden div's onclick attribute and clicking it.	REPORTED	2026-10-07	[S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`localStorage key: 136c1e07507f4a97`	Payload persistence key used by the March 2026 PolyShell-wave loader.	REPORTED	2026-03-30	[S7] [S9]
other	`localStorage key: 136c1e07507f4a98`	Related payload persistence key listed by Sansec.	REPORTED		[S7]
other	`aHR0cHM6Ly9hZGRpdGlvbmFsdmVyLmNvbS9NYjJ6OEo/JnNlX3JlZmVycmVyPQ==`	Base64-encoded Keitaro campaign URL (additionalver.com) embedded in injected CMS content.	REPORTED		[S7]
other	`QWE=123;`	Decoy response that the loader infrastructure returns.	REPORTED		[S7]
other	`se_referrer= / frm=script` query parameters	Keitaro request format the loader uses (campaign alias path plus referrer, page title and query string).	REPORTED		[S7] [S9]
other	`Database: cms_block.content / cms_page.content` containing `fpCode`, `se_referrer` or `localStorage.getItem`	Where the loader is stored. Check update_time for the attacker's most recent write.	REPORTED		[S7]
http-request	`POST /V1/guest-carts/:cartId/items` with `file_info` (base64 file data, MIME type, filename)	Unauthenticated PolyShell upload request. Image-header polyglot files contain PHP.	REPORTED	2026-03-19	[S8]
http-request	`PUT /V1/guest-carts/:cartId/items/:itemId` with `file_info`	Second unauthenticated PolyShell upload route.	REPORTED	2026-03-19	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST /rest/V1/guest-carts/*/items and /rest/<store_code>/V1/guest-carts/*/items`	Magento serves REST routes under /rest/ (optionally with a store code), so this is the full path that will appear in web server logs.	DERIVED		[S8]
http-request	`GET /pub/media/custom_options/quote/*.php (also /media/custom_options/quote/*.php)`	Access to an uploaded webshell. Any request for an executable file under custom_options shows an attempt to execute uploaded code.	DERIVED		[S8]
filepath	`pub/media/custom_options/quote/`	PolyShell upload directory. PNG-disguised webshells are dropped here. Any .php, .phtml or .phar file here is a strong sign of compromise.	REPORTED		[S8] [S7]
filepath	`pub/media/customer_address/`	Directory Sansec recommends checking for uploaded files.	REPORTED		[S7]
filepath	`var/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`bamboo-specs/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`lib/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`app/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`vendor/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`pub/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filepath	`bin/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`setup/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`generated/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filepath	`phpserver/assets/images/accesson.php`	accesson.php backdoor drop location.	REPORTED	2026-03-30	[S8]
filename	`accesson.php`	Backdoor dropped by the PolyShell webshell in several directories.	REPORTED	2026-03-30	[S8] [S9] [S7]
filename	`index.php`	Uploaded PolyShell filename when it appears under custom_options. Runs on stock nginx configurations for Magento 2.0.0-2.2.x.	REPORTED		[S8]
filename	`780index.php`	Uploaded filename (option ID prefixed to index.php).	REPORTED		[S8]
filename	`json-shell.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`bypass.phtml`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`c.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`r.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`rce.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`static.php`	Uploaded PolyShell filename (under custom_options). Do not confuse it with Magento's legitimate pub/static.php.	REPORTED		[S8]
filename	`test.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`blocked-json.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`bypass-async.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`urlencode-shell.php`	Uploaded PolyShell filename.	REPORTED		[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
filename	`xx_malicious_file.php`	Uploaded PolyShell filename.	REPORTED		[S8]
filename	`ato_poc.html`	Uploaded file seen in PolyShell activity (stored XSS / probing).	REPORTED		[S8]
filename	`mikhail.html`	Uploaded file seen in PolyShell activity.	REPORTED		[S8]
filename	`toggige-arrow.jpg`	Uploaded file seen in PolyShell activity.	REPORTED		[S8]
filename	`adman.429.txt`	Uploaded file seen in PolyShell activity.	REPORTED		[S8]
filename	`adman.309.txt`	Uploaded file seen in PolyShell activity.	REPORTED		[S8]
filename	`\u0062\u0079\u0070\u0061\u0073\u0073.\u0070\u0068\u0070`	Unicode-escaped upload filename that decodes to bypass.php.	REPORTED		[S8]
other	`a17028468cb2a870d460676d6d6da3ad63706778e3`	Hardcoded hash that the PolyShell webshell compares against a cookie named 'd'. Useful as a content string for file grep. It is not a file hash.	REPORTED		[S8]
other	`4009d3fa8132195a2dab4dfa3affc8d2`	Double-MD5 password hash embedded in the password-protected webshell variant. Use it as a content string, not a file hash.	REPORTED		[S8]
other	`8194460`	Webshell/backdoor beacon output (result of 409723*20). Seen in HTTP responses from compromised stores.	REPORTED	2026-03-30	[S8] [S9]
other	`Webshell code patterns: eval(base64_decode(...)), system(), $_POST["up"] upload parameter`	Behavior of PolyShell webshells. Useful as YARA or grep strings under the Magento root.	REPORTED		[S8]
other	`GSocket backdoor`	Sansec found a GSocket backdoor on one compromised store. Check running processes.	REPORTED		[S7]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`3[.]12[.]250[.]83`	PolyShell scanning source (March 2026). AWS address, so it may be shared or reassigned.	REPORTED	2026-03	[S8]
ipv4	`3[.]88[.]149[.]41`	PolyShell scanning source (March 2026). AWS address.	REPORTED	2026-03	[S8]
ipv4	`3[.]150[.]234[.]247`	PolyShell scanning source (March 2026). AWS address.	REPORTED	2026-03	[S8]
ipv4	`18[.]220[.]50[.]153`	PolyShell scanning source (March 2026). AWS address.	REPORTED	2026-03	[S8]
ipv4	`23[.]22[.]254[.]35`	PolyShell scanning source (March 2026). AWS address.	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]0[.]53`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]1[.]34`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]7[.]117`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]11[.]173`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]15[.]89`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`31[.]134[.]15[.]251`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]136[.]24[.]213`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]136[.]26[.]181`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]136[.]27[.]218`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]147[.]233[.]211`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]147[.]234[.]73`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`45[.]155[.]166[.]228`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`52[.]24[.]6[.]119`	PolyShell scanning source (March 2026). AWS address.	REPORTED	2026-03	[S8]
ipv4	`64[.]49[.]38[.]96`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`78[.]129[.]161[.]63`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`79[.]130[.]2[.]23`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`81[.]169[.]144[.]135`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`91[.]132[.]124[.]183`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`103[.]216[.]223[.]206`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`109[.]107[.]178[.]102`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`115[.]79[.]194[.]68`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`136[.]244[.]92[.]114`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`140[.]235[.]2[.]103`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`140[.]235[.]171[.]72`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`140[.]248[.]75[.]31`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`140[.]248[.]75[.]114`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`162[.]159[.]113[.]66`	PolyShell scanning source (March 2026). Falls in Cloudflare address space, so blocking it risks false positives. Use for log correlation only.	REPORTED	2026-03	[S8]
ipv4	`185[.]3[.]235[.]111`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
ipv4	`193[.]151[.]188[.]86`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`193[.]233[.]216[.]217`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`193[.]233[.]221[.]124`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`194[.]180[.]233[.]186`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`198[.]186[.]130[.]10`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`199[.]96[.]165[.]186`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`212[.]87[.]218[.]43`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`216[.]38[.]6[.]137`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv6	`2001[:]19f0[:]6c01[:]15da[:]5400[:]6ff[:]fe05[:]e560`	PolyShell scanning source (March 2026).	REPORTED	2026-03	[S8]
ipv4	`94[.]154[.]43[.]7`	Node2Shell (CVE-2026-111497) exploit source seen by ELLIO, geolocated to the Netherlands. Also linked to PHP2Shell exploitation, GlobalProtect/FortiOS SSL VPN probing and Kubernetes API scanning. ELLIO first saw it 2025-12-15.	REPORTED	2025-12-15	[S10] [S1]
sha256	`7fcbdaaecd4419e2930927844f3b772668204737a4e7602a2290c991c93c5c4b`	SHA-256 of the 23,069,983-byte Brotli-encoded exploit request body seen by ELLIO. It targets Node.js v24.22.0 x86-64.	REPORTED	2026-10-26	[S10]
user-agent	`Mozilla/5.0 (compatible; node2shell-check/1.0)`	Scanner that maps which hosts decompress Brotli request bodies. It sends 20 POSTs with Content-Encoding: br after GET /. An AS44620 (Turkey) address used it from 2026-06-13 onward.	REPORTED	2026-06-13	[S10]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
http-request	`POST with header Content-Encoding: br (inbound request body)`	Delivery method for Node2Shell probes and exploits. Legitimate clients rarely send Brotli-compressed request bodies, so it is worth monitoring. Probe sizes were 1,032 bytes (malformed) and up to 65,743 bytes. The exploit body was about 23 MB.	REPORTED	2026-10-26	[S10]
command	`/bin/sh (stdin redirected, spawned by node)`	A successful payload connects stdin to /bin/sh. A shell child process of a Node.js server process is therefore a post-exploitation signal.	REPORTED	2026-10-26	[S10]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

PolyShell (CVE-2026-48356): unauthenticated attackers send POST or PUT requests to Magento's guest-cart REST endpoints with a file_info object. It holds a base64 image/PHP polyglot that passes the only check (getimagesizefromstring). The file lands in pub/media/custom_options/quote/, and on web server configurations that execute PHP there, attackers then request it to run a webshell. The webshells use cookie or password authentication with eval/system. They drop accesson.php backdoors across many directories, and attackers then write an obfuscated JavaScript loader into the cms_block and cms_page database tables. The loader persists in visitors' browsers through localStorage, fingerprints them to filter out bots and scanners, and routes selected visitors through a Keitaro traffic distribution system to payloads. Payloads seen in December 2025 led to crypto-themed lure domains [S7] [S8] [S9]. Node2Shell (CVE-2026-111497): an out-of-bounds write in the Brotli decoder. A crafted Brotli stream can corrupt memory in any process that decodes attacker-influenced data, including Node.js request bodies with Content-Encoding: br, fetch() of Brotli responses and direct zlib calls. Seen in the wild: a node2shell-check scanner fingerprints Brotli-decoding hosts, then a separate source sends a multi-stage exploit body with a ROP chain built for one Node.js build, which aims to connect stdin to /bin/sh. Failed attempts crash workers [S10] [S1] [S11].

Threat actor

Unnamed Magento CMS-block loader operator (Sansec-tracked; latest infrastructure deepveindrilling[.]com)

Attribution confidence: Low · **Motivation:** Likely financial (traffic monetization, crypto-wallet-themed lures). The final payload is unconfirmed. · **Suspected origin:** Unknown

Sansec links five loader domains (July 2025 to October 2026) to one operator through shared code and overlapping victims. No public attribution to a named group. The Node2Shell exploitation (94.154.43[.]7) is a separate, unattributed mass-exploitation operator, and there is no evidence linking the two.

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Reconnaissance	T1595.002 Active Scanning: Vulnerability Scanning	node2shell-check scanner sends benign and malformed Brotli bodies to find hosts that decompress them. PolyShell mass scanning began 2026-03-23. [S10] [S8]	Alert on the node2shell-check user agent and on bursts of POSTs with Content-Encoding: br. Watch for spikes in guest-cart REST calls from a single source.
Initial Access	T1190 Exploit Public-Facing Application	Unauthenticated upload of a polyglot PHP file through the Magento guest-cart REST API (CVE-2026-48356). A crafted Brotli request body corrupts Node.js memory (CVE-2026-111497). [S8] [S10] [S4]	WAF/web logs: POST or PUT to /rest/*/V1/guest-carts/*/items with large bodies containing file_info. Inbound Content-Encoding: br requests followed by Node worker crashes.
Persistence	T1505.003 Server Software Component: Web Shell	PHP webshells in pub/media/custom_options/quote/ and accesson.php backdoors in */assets/images/ directories. [S8] [S9]	File integrity monitoring on the Magento root. Find executable files under pub/media/custom_options/ and any accesson.php.
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Webshell variant calls system(). The Node2Shell ROP chain connects stdin to /bin/sh. GSocket backdoor found on one store. [S8] [S10] [S7]	EDR: sh/bash child processes of php-fpm or node. Look for gs-netcat or gsocket processes.
Persistence	T1136 Create Account	Rogue rows added to the Magento admin_user table. [S7]	Diff admin_user against an approved list and alert on new admin accounts.
Defense Evasion	T1027 Obfuscated Files or Information	Obfuscated JavaScript loader, base64-encoded Keitaro URLs and a Unicode-escaped upload filename. [S7] [S8]	Search CMS content for base64 blobs, se_referrer, fpCode and localStorage.getItem.
Defense Evasion	T1497 Virtualization/Sandbox Evasion	Version 2 loader fingerprints navigator.webdriver, Selenium/ChromeDriver artifacts, GPU and screen. The server returns nothing to bots and scanners. [S7]	Inspect the stored CMS content directly instead of relying on external page scans.
Command and Control	T1102 Web Service	Keitaro TDS decides per visitor whether to serve a payload, a redirect or nothing. [S7]	Proxy/DNS alerts for the loader domains. CSP violation reports for unexpected script sources.

Tactic	Technique	Procedure observed	Detection opportunity
Impact	T1491.002 Defacement: External Defacement	Malicious script injected into storefront pages through cms_block, serving content to shoppers. [S7]	Content Security Policy enforcement and reporting. Periodic diffs of CMS block content.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Failed Node2Shell attempts crash Node.js workers. Repeated restarts give the attacker fresh memory layouts to try. [S10]	Monitor for crash loops and abnormal worker restarts of Node.js services, and for new core dumps.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

PolyShell upload or webshell access in Magento web logs `SPLUNK SPL`

```
index=web (sourcetype=nginx:access OR sourcetype=access_combined)
( (http_method IN ("POST","PUT") uri_path="*/V1/guest-carts/*/items*")
  OR uri_path="*/media/custom_options/*"
  OR uri_path="*accesson.php*" )
| eval suspicious=case(match(uri_path, "(?i)custom_options/.*\.(php|phtml|phar)"), "webshell_exec",
match(uri_path, "(?i)accesson\.php"), "backdoor", true(), "guest_cart_write")
| stats count values(uri_path) as paths values(status) as statuses min(_time) as first max(_time) as
last by src_ip suspicious host
| sort - count
```

Guest-cart writes are normal shopping traffic, so look for high volume from one source or large request sizes. Any 200 response for an executable file under custom_options needs investigating.

Node2Shell probing: Brotli-encoded request bodies or node2shell-check user agent `SURICATA`

```
alert http any any -> $HOME_NET any (msg:"LUCIDIA Possible Node2Shell CVE-2026-111497 scanner UA";
flow:established,to_server; http.user_agent; content:"node2shell-check"; nocase; classtype:attempted-
admin; sid:9260111; rev:1;)
alert http any any -> $HOME_NET any (msg:"LUCIDIA Inbound Brotli-encoded HTTP request body
(CVE-2026-111497 vector)"; flow:established,to_server; http.method; content:"POST"; http.header;
content:"Content-Encoding|3a 20|br"; nocase; threshold:type limit, track by_src, count 1, seconds 600;
classtype:attempted-admin; sid:9260112; rev:1;)
```

Needs TLS termination or a sensor behind the load balancer. The second rule is broad. Tune it out for known API clients that legitimately send Brotli bodies.

Shell spawned by Node.js or PHP-FPM on Linux web servers `KQL`

```
DeviceProcessEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~ ("node", "nodejs", "bun", "php-fpm", "php") or
InitiatingProcessFileName startswith "php-fpm"
| where FileName in~ ("sh", "bash", "dash", "gs-netcat", "curl", "wget")
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName,
ProcessCommandLine, AccountName
| order by Timestamp desc
```

Some build tooling and npm scripts spawn shells legitimately, so baseline first. Production web workers spawning a shell is high-signal.

Executable files written under Magento media upload directories `SIGMA`

```
title: Executable File Written to Magento custom_options or customer_address
status: experimental
logsource:
  product: linux
  category: file_event
detection:
  selection_dir:
    TargetFilename|contains:
      - '/pub/media/custom_options/'
      - '/pub/media/customer_address/'
  selection_ext:
    TargetFilename|endswith:
      - '.php'
      - '.phtml'
      - '.phar'
  selection_backdoor:
    TargetFilename|endswith: '/assets/images/accesson.php'
  condition: (selection_dir and selection_ext) or selection_backdoor
falsepositives:
  - Unlikely
level: high
```

Needs auditd or EDR file-creation telemetry on Magento hosts. Pair it with a one-time find sweep for files already on disk.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Adobe Commerce	2.4.9; 2.4.8-p5, 2.4.7-p10, 2.4.6-p15, 2.4.5-p17, 2.4.4-p18 and earlier	2.4.9-2026-jul, 2.4.8-2026-jul, 2.4.7-2026-jul, 2.4.6-2026-jul, 2.4.5-2026-jul, 2.4.4-2026-jul (APSB26-73)	CVE-2026-48356	9.3 (CVE record, v3.1); Adobe bulletin lists 9.6	0.306 (98.2nd pct, 2026-10-27)	Yes (added 2026-10-27)	2026-11-10
Magento Open Source	2.4.9; 2.4.8-p5, 2.4.7-p10, 2.4.6-p15 and earlier	2.4.9-2026-jul, 2.4.8-2026-jul, 2.4.7-2026-jul, 2.4.6-2026-jul	CVE-2026-48356	9.3	0.306	Yes (added 2026-10-27)	2026-11-10
Adobe Commerce B2B / Commerce Events	B2B 1.5.3, 1.5.2-p5, 1.4.2-p10, 1.3.4-p17, 1.3.3-p18 and earlier; Events 1.20.0 and earlier	B2B *-2026-jul releases; Events 1.21.0	CVE-2026-48356	9.3	0.306	Yes (added 2026-10-27)	2026-11-10
Google Brotli (C library)	1.0.3 to before 1.0.10; 1.1.0 to before 1.1.1; 1.2.0 to before 1.2.1	1.0.10, 1.1.1, 1.2.1 (2026-10-21)	CVE-2026-111497	9.2 (CVSS v4.0)	0.555 (99.0th pct, 2026-10-27)	Yes (added 2026-10-27)	2026-11-10
Node.js (bundled Brotli)	22.x before 22.23.4, 24.x before 24.22.1, 26.x before 26.12.1; EOL 20.x, 23.x, 25.x and older (no fix)	22.23.4, 24.22.1, 26.12.1	CVE-2026-111497	9.2	0.555	Yes (added 2026-10-27)	2026-11-10

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Other Brotli consumers (Bun, Python Brotli/ brotlicffi, Envoy/Istio, PHP brotli, Ruby brotli gem, .NET, Debian/ Alpine packages)	Builds embedding vulnerable Brotli	Bun 1.4.4; PyPI Brotli 1.2.1 / brotlicffi 1.2.1.0; Envoy 1.40.0, 1.39.3, 1.38.6, 1.37.8, 1.36.12; Ruby brotli 0.9.1/0.9.2; Debian 1.0.9-2+deb12u1 / 1.1.0-2+deb13u1; Alpine 1.2.1-r0 / 1.1.1-r0; others per vendor advisory	CVE-2026-111497	9.2	0.555	Yes (added 2026-10-27)	2026-11-10

Immediate (0–24 hours)

- Inventory every Magento/Adobe Commerce store managed for clients. Confirm each one runs an APSB26-73 *-2026-jul release, and patch any that do not. `IT OPS` [S2] [S5] [S4]
- Block web access and PHP execution under pub/media/custom_options/. In nginx, place a deny location before the \.php$ handler. In Apache, confirm the .htaccess sets php_flag engine 0 and Deny from all. `IT OPS` [S8]
- On every store, patched or not, query cms_block and cms_page for fpCode, se_referrer, localStorage.getItem and the listed loader domains. Run find for files under pub/media/custom_options/ and pub/media/customer_address/ and for accesson.php. Review admin_user. `SOC` [S7] [S8]
- Identify internet-facing Node.js services and upgrade them to 22.23.4, 24.22.1 or 26.12.1. Rebuild container images, regenerate lockfiles and restart processes. Check the Node release version, not process.versions.brotli. `IT OPS` [S10] [S11] [S1]
- Where it will not break clients, reject inbound requests with Content-Encoding: br at the WAF, reverse proxy or application until patching is complete. `IT OPS` [S10]
- Add the Node2Shell indicators (94.154.43.7, the node2shell-check UA) and the CMS-loader domains to blocklists and SIEM watchlists, and search logs back to June 2026. `SOC` [S10] [S7]

Short term (1–7 days)

- For any store with indicators, remove the injected CMS content and webshells and delete rogue admins and backdoors (including GSocket). Rotate database, admin and API integration credentials, then rescan. Patching alone does not remove attacker access. `SOC` [S7]
- Confirm SessionReaper (CVE-2025-54236, APSB25-88) is also patched. Earlier waves of this campaign predate PolyShell. `IT OPS` [S7]
- Use SBOM or software composition scans to find embedded Brotli in Bun-compiled binaries, Python and Ruby packages, Envoy/Istio meshes, PHP extensions, .NET and OS packages. Apply each vendor's fix. `IT OPS` [S10] [S1]

- Restrict access to Node.js core dumps and shorten their retention. Treat crash-loop alerts on internet-facing Node services as possible exploitation, and rotate any secrets the affected process held. `SOC` [S10]
- Patch staging, CI runners, build images, serverless runtimes and developer machines, not just production. `IT OPS` [S10]

Long term

- Move Node.js workloads off end-of-life release lines (20.x and older, 23.x, 25.x) and adopt a patch SLA for runtime security releases. `LEADERSHIP` [S10] [S11]
- Deploy file integrity monitoring and a strict Content Security Policy with reporting on e-commerce storefronts so injected scripts are detected quickly. `IT OPS` [S7]
- Budget for an e-commerce WAF or virtual patching layer for client Magento sites, and include e-commerce platforms in monthly KEV review. `LEADERSHIP` [S7] [S8]

Workarounds & compensating controls

- A WAF rule that blocks file_info payloads on guest-cart REST endpoints. Blocking the directory alone does not stop uploads. `IT OPS` [S8]
- Edge or WAF rules that drop inbound Brotli-encoded request bodies (for example, the emergency rules Cloudflare and Vercel shipped). These do not protect outbound fetch() of Brotli responses. `IT OPS` [S1] [S11]
- Where the code can be changed, avoid decoding Brotli from untrusted upstreams in outbound HTTP clients (for example, do not advertise br in Accept-Encoding) until runtimes are patched. `IT OPS` [S10] [S11]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Adobe Commerce PolyShell attacks breach stores; CISA adds PolyShell and Brotli flaws to KEV
Published 2026-10-28 · `B2` Usually reliable, probably true
Briefing source. Only source for the Previdian, Wiz and Sysdig figures, which we did not verify against the originals.

[S2] Adobe: APSB26-73: Security update available for Adobe Commerce
Published 2026-07-14 · `A2` Completely reliable, probably true
Vendor advisory. Last updated 2026-08-11. Still says no known exploits and lists CVSS 9.6, which conflicts with the CVE record (9.3).

[S3] Google (GitHub): google/brotli release v1.2.1
Published 2026-10-21 · `A1` Completely reliable, confirmed by other sources
Upstream fix release referencing CVE-2026-111497.

[S4] CISA: Known Exploited Vulnerabilities Catalog (version 2026.10.27)
Published 2026-10-27 · `A1` Completely reliable, confirmed by other sources
Both CVEs added 2026-10-27, due 2026-11-10, ransomware use Unknown.

[S5] CVE Program (Adobe CNA): CVE-2026-48356 record
Published 2026-07-14 · `A2` Completely reliable, probably true
CVSS 3.1 9.3 with UI:R, which is at odds with Sansec's unauthenticated, no-interaction exploitation. References the Sansec research.

[S6] CVE Program (Google CNA): CVE-2026-111497 record
Published 2026-10-22 · `A1` Completely reliable, confirmed by other sources
CVSS 4.0 9.2. CWE-787/CWE-252. Affected Brotli 1.0.3 through 1.2.0.

[S7] Sansec: Magento CMS block loader campaign (deepveindrilling.com)
Published 2026-10-24 · `A2` Completely reliable, probably true
Original research. 953 stores, loader IOCs, cleanup guidance.

[S8] Sansec: PolyShell: unauthenticated file upload in Magento (CVE-2026-48356)
Published 2026-03-17 · `A2` Completely reliable, probably true
Original technical advisory with endpoints, filenames, paths, hashes, scanning IPs and server mitigations. Parts of it were written in March 2026.

[S9] Sansec: Mass PolyShell attack wave hits 471 stores in one hour
Published 2026-03-30 · `A2` Completely reliable, probably true
March 2026 wave IOCs.

[S10] ELLIO: Node2Shell: remote code execution on stock Node.js builds (CVE-2026-111497)
Published 2026-10-25 · `B2` Usually reliable, probably true
Original in-the-wild observation, IOCs and fixed versions across ecosystems. The exploit did not succeed in ELLIO's testing.

[S11] The Hacker News: Node.js Brotli decoder bug could allow remote code execution
Published 2026-10-22 · `B2` Usually reliable, probably true
Node.js 2026-10-21 security release context. Public PoC 2026-10-22. No in-the-wild exploitation as of 2026-10-22.

[S12] FIRST: EPSS API scores for CVE-2026-48356 and CVE-2026-111497
Published 2026-10-27 · `A2` Completely reliable, probably true
Model output, not observed exploitation.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2025-07-09	First store seen loading the operator's manulfie[.]click CMS-block loader (before PolyShell was discovered).	[S7]
2025-12-12	Operator switches the loader to neswnsssn[.]click. Payloads lead to crypto-themed domains.	[S7]
2026-02-27	Brotli fix committed upstream without a release or advisory.	[S10] [S6]
2026-03-17	Sansec publicly discloses PolyShell. No official patch for production versions yet.	[S8]
2026-03-19	First PolyShell attacks seen in the wild. Mass scanning starts 2026-03-23.	[S8]
2026-03-30	PolyShell mass wave puts the lanhd6549tdhse[.]top loader on 471 stores in one hour.	[S9] [S7]
2026-05-12	Magento 2.4.9 released with the PolyShell fix (not backported at the time).	[S8]
2026-06-13	ELLIO first sees the node2shell-check scanner address.	[S10]
2026-07-14	Adobe publishes APSB26-73 with backported fixes. CVE-2026-48356 published.	[S2] [S5]
2026-10-07	deepveindrilling[.]com loader first served from compromised stores.	[S7]
2026-10-21	Brotli 1.0.10/1.1.1/1.2.1 and Node.js 22.23.4/24.22.1/26.12.1 released.	[S3] [S11]
2026-10-22	CVE-2026-111497 published. Public proof-of-concept appears.	[S6] [S11]
2026-10-23	Operator rewrites CMS blocks with a fingerprinting loader, including on a patched store.	[S7]
2026-10-24	Sansec publishes the CMS-block loader research (953 stores).	[S7]
2026-10-26	ELLIO reports Node2Shell exploit traffic from 94.154.43[.]7.	[S10] [S1]

Date	Event	Source
2026-10-27	CISA adds both CVEs to KEV, with a due date of 2026-11-10.	[S4]
2026-11-10	KEV remediation due date for FCEB agencies.	[S4]

Relevance to Indianapolis, Indiana & Lucidia IT clients

Magento and Adobe Commerce are common among Indiana retailers, specialty manufacturers and distributors that run B2B ordering portals, and among small and mid-size online sellers. Many of these sites are run by small agencies or hosts and lag on patches. For Lucidia IT clients with Magento storefronts, the main risk is a store that was infected earlier, quietly serves malicious script to shoppers, and keeps the attacker's database access after patching. That creates exposure under payment-card (PCI DSS) rules, customer notification duties under Indiana's breach notification law, and reputational harm. The Brotli flaw reaches much further. Node.js is behind many web apps, patient and student portals, internal APIs and SaaS integrations at Indiana hospitals, universities, school districts, local governments and manufacturers. Brotli is also embedded in proxies, service meshes and vendor appliances that clients may not know they run. State and local government entities that follow CISA KEV timelines should treat 2026-11-10 as the target. Lucidia IT should run a client-wide Node.js and Brotli exposure sweep through RMM and vulnerability scanning, check upstream vendors' advisories for embedded Brotli, and offer Magento compromise assessments, not just patching.

Intelligence gaps

- The final payload of the current deepveindrilling[.]com loader is unknown. Sansec has not captured it.
- We do not know how many of the 953 stores were first compromised through PolyShell rather than earlier flaws such as SessionReaper.
- No public attribution exists for the CMS-loader operator or the Node2Shell exploit source.
- It is unconfirmed whether any Node2Shell exploitation has achieved code execution on stock builds in the wild. ELLIO's test of the observed payload failed.
- The Previdian honeypot detection and Wiz's 91% exposure figure come only from The Hacker News. We did not review the originals.
- Adobe's bulletin has not been updated to reflect exploitation, and its CVSS (9.6) differs from the CVE record (9.3). The CVE vector's UI:R conflicts with observed unauthenticated exploitation.
- The full list of commercial appliances and products that embed vulnerable Brotli, and their patch timelines, is still incomplete.
- No file hashes for PolyShell webshells or accesson.php were published, and there are no recent IPs for the CMS-loader operator.

Other notes

- The Node.js release of 2026-10-21 fixed nine other CVEs alongside Brotli, including TLS hostname-check bypasses (CVE-2026-106069, CVE-2026-105483), and blocked eight eMudhra intermediate CA keys [S11].
- The Node2Shell exploit source 94.154.43[.]7 is also tied to PHP2Shell exploitation and VPN probing, which suggests an opportunistic multi-exploit operator [S10] [S1].
- process.versions.brotli reports 1.2.0 on both patched and unpatched Node.js builds, so version checks must

use the Node.js release number [S10].

- Sansec reports the operator re-infecting stores that were already patched, which points to retained database or credential access. Incident response must include credential rotation [S7].
- Several scanning IPs from the March 2026 PolyShell list belong to AWS and Cloudflare ranges. Do not block them broadly. Use them for retrospective log correlation.

LIT-CTI-20261028-03 v1.0 · Generated 2026-10-28 08:08 EDT from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

TLP:CLEAR Unrestricted public release.